

Dalam CTF kategori **Cryptography**, topik **Attack on PRNG (Pseudo Random Number Generator)** sering muncul karena banyak sistem menggunakan angka "acak" untuk menghasilkan token, nonce, session ID, atau bahkan kunci kriptografi.

Masalahnya, PRNG **deterministik**. Jika algoritma atau state internalnya dapat ditebak, seluruh output masa depan bisa diprediksi.

---

## 1. Linear Congruential Generator (LCG)

LCG adalah PRNG sederhana dengan rumus:

$$X_{n+1} = (aX_n + c) \bmod m$$

di mana:

- $(X_n)$  = state saat ini
  - $(a)$  = multiplier
  - $(c)$  = increment
  - $(m)$  = modulus
- 

### Contoh Challenge CTF

$a = 1103515245$

$c = 12345$

$m = 2^{*}31$

`seed = secret_seed`

`def rand():`

`global seed`

`seed = (a * seed + c) % m`

`return seed`

`print(rand())`

`print(rand())`

`print(rand())`

Output:

1250496027

1116302264

1000676753

Flag:

```
flag = "CTF{" + str(next_rand) + "}"
```

---

### Ide Serangan

Diketahui:

x1

x2

x3

dan parameter:

a,c,m

Maka:

$$x4 = (a * x3 + c) \bmod m$$

langsung bisa dihitung.

---

### Solusi

a = 1103515245

c = 12345

m = 2\*\*31

x3 = 1000676753

$$x4 = (a * x3 + c) \% m$$

```
print(x4)
```

---

### Tingkat Kesulitan

Easy

Biasanya muncul pada CTF pemula.

---

## 2. Recover Parameter LCG

Kadang nilai:

a

c

m

disembunyikan.

Diberikan:

$x_0$

$x_1$

$x_2$

$x_3$

Tugas:

cari output berikutnya

---

### Teknik

Hitung:

$$t_0 = x_1 - x_0$$

$$t_1 = x_2 - x_1$$

$$t_2 = x_3 - x_2$$

Dari sifat LCG:

$$t_1 = a \cdot t_0 \bmod m$$

$$t_2 = a \cdot t_1 \bmod m$$

Kita bisa memulihkan:

m

a

c

menggunakan operasi gcd.

Ini sering muncul pada challenge:

Predict the lottery

Predict next token

Guess the admin password reset code

---

### 3. Mersenne Twister (MT19937)

PRNG yang sangat populer.

Digunakan oleh:

- Python random
- PHP lama
- banyak aplikasi web

State internal:

624 angka 32-bit

Total:

$624 \times 32 = 19968$  bit

Karena itu namanya:

MT19937

---

### Kesalahan Umum

Developer menggunakan:

```
import random
```

```
token = random.getrandbits(32)
```

untuk token keamanan.

Padahal:

```
random
```

bukan CSPRNG.

---

### Challenge CTF

Server memberi:

```
for i in range(624):
```

```
    print(random.getrandbits(32))
```

lalu:

```
flag = random.getrandbits(32)
```

---

### **Ide Serangan**

Jika memperoleh:

624 output

kita dapat:

clone state MT19937

secara sempurna.

Lalu menghasilkan output berikutnya.

---

### **Langkah**

MT melakukan proses:

state -> temper -> output

Kita lakukan:

output -> untemper -> state

sebanyak:

624 kali

Setelah seluruh state diketahui:

prediksi semua output berikutnya

---

### **Tool Populer**

pip install randcrack

Contoh:

```
from randcrack import RandCrack
```

```
rc = RandCrack()
```

```
for _ in range(624):
```

```
    rc.submit(observed_output)
```

```
print(rc.predict_getrandbits(32))
```

---

### **Tingkat Kesulitan**

Medium

Sangat sering muncul di CTF.

---

### **4. Seed Recovery MT19937**

Kadang output tidak cukup untuk clone state.

Tetapi seed dibuat dari waktu.

Misal:

```
seed = int(time.time())
```

```
random.seed(seed)
```

---

### **Challenge**

Output:

3499211612

Server baru dijalankan beberapa menit lalu.

---

### **Ide Serangan**

Bruteforce:

timestamp sekarang  $\pm$  beberapa menit

Jumlah kandidat:

ratusan atau ribuan

saja.

---

### **Solusi**

```
import random
```

```
import time
```

```
target = 3499211612
```

```
now = int(time.time())
```

```
for s in range(now-10000, now+1):
```

```
    random.seed(s)
```

```
    if random.getrandbits(32) == target:
```

```
        print("seed =", s)
```

```
        break
```

---

### Tingkat Kesulitan

Easy–Medium

Sangat populer pada challenge web dan crypto.

---

### 5. LFSR (Linear Feedback Shift Register)

LFSR banyak muncul pada challenge crypto klasik.

State berupa bit:

10110101

Setiap langkah:

geser

+

bit baru = XOR beberapa posisi

---

### Contoh

State:

1101

Tap:

[4,1]

Artinya:

$\text{newbit} = \text{bit4} \text{ XOR } \text{bit1}$

---

### Challenge

Diberikan stream:

101110011010011...

Tugas:

recover state

recover flag

---

### Serangan Berlekamp-Massey

Algoritma terkenal untuk menemukan:

panjang register

feedback polynomial

dari output.

Jika cukup banyak bit diketahui:

seluruh state dapat direkonstruksi

---

### Contoh Soal

$\text{key\_stream} = \text{LFSR}(\text{secret\_state})$

$\text{cipher} = \text{plaintext} \text{ XOR } \text{key\_stream}$

Diberikan:

ciphertext

dan sebagian plaintext diketahui.

---

### Ide

Dapatkan:

keystream

kemudian jalankan:

Berlekamp-Massey



untuk memulihkan LFSR.

---

### Tool

from sage.all import berlekamp\_massey

---

## 6. Gabungan LFSR (Geffe Generator)

Challenge yang lebih sulit sering menggunakan beberapa LFSR.

Misalnya:

LFSR1

LFSR2

LFSR3

digabung dengan fungsi:

$(x \text{ AND } y) \text{ XOR } (\sim x \text{ AND } z)$

Ini disebut:

Geffe Generator

---

### Serangan

Menggunakan:

- Correlation Attack
- Fast Correlation Attack

untuk menemukan state masing-masing register.

---

### Tingkat Kesulitan

Hard

Biasanya final atau advanced crypto.

---

### Contoh Soal Jeopardy CTF

#### Easy — Predict the Lottery

seed = 1337

```
def rand():  
    global seed  
    seed = (1103515245*seed + 12345) % (2**31)  
    return seed
```

```
print(rand())
```

```
print(rand())
```

```
print(rand())
```

Flag:

CTF{next\_output}

---

### Medium — Clone MT19937

Server memberikan:

624 output random.getrandbits(32)

Flag:

CTF{next\_output}

---

### Medium — Time Seed Attack

```
random.seed(int(time.time()))
```

Diberikan:

first\_output

Cari seed.

---

### Hard — LFSR Stream Cipher

Diberikan:

ciphertext

dan sebagian plaintext.

Recover:

secret state

---

## Ringkasan Attack PRNG di CTF

| PRNG                   | Teknik Serangan             | Kesulitan   |
|------------------------|-----------------------------|-------------|
| LCG                    | Prediksi output berikutnya  | Easy        |
| LCG Unknown Parameters | Recover $a, c, m$           | Medium      |
| MT19937                | Clone state dari 624 output | Medium      |
| MT19937 Time Seed      | Bruteforce timestamp        | Easy–Medium |
| LFSR                   | Berlekamp-Massey            | Medium      |
| Geffe Generator        | Correlation Attack          | Hard        |

Dalam CTF modern, yang paling sering muncul adalah **MT19937 state recovery**, **timestamp seed attack**, dan **LFSR stream cipher**, karena ketiganya realistis dan menunjukkan mengapa PRNG biasa tidak boleh digunakan untuk kriptografi.